

QC-SOP-003 — Account, permission and session management

Revision D0.2 | DRAFT FOR REVIEW | Revised 2026-10-04

Effective date: not recorded. Approval/signature: not recorded. This draft does not authorize testing, release, production changes or UAT acceptance.

1. Purpose and scope

Manage account creation, role assignment, activation, deactivation, password recovery and session revocation.

Implementation: SOURCE-ALIGNED DRAFT

2. Responsibilities and review

Responsible specialists: Named System Owner; Authorized identity administrator

Review: Named System Owner; Authorized identity administrator

Approval: Authorized QMS / Document Control approver under the approved document policy; not yet established for this draft

3. Before you start

- The approved access request names the person and required work.
- The administrator has the exact identity permission and scope.
- OD-2026-09-23-RBAC-01 is the authority source for QC roles.

4. Procedure

1. Confirm the requester and business need before opening the user register. Record the approved role and permission scope; do not grant authority from a job title alone.
2. Map QC 01, QC 02 and QC 03 to EMPLOYEE with the same QC entry bundle. Supervisor is SUPERVISOR; QCM is MANAGER. Owner authority requires the active named loginIdentity yazeed in addition to SYSTEM_OWNER.
3. Create or update the account through the server operation and review the returned safe account details. Do not expose password hashes, credentials or session tokens in support evidence.
4. Check that entry permissions allow eligible creation, editing and submission while review, signing, release, close, attestation, finalization and void remain denied to QC entry users.
5. Activate an eligible account only after approved provisioning. Disable or revoke sessions when access is withdrawn; preserve identity history used by earlier records.
6. Use self-service password change or the authorized administrative reset. Verify success and revoked-session behavior; credential and session changes are transactional with audit.
7. At login, let the pending request resolve. Respect throttle feedback. After expiry, sign in again and reopen the record from a safe local return path.
8. Periodically review actual grants against approved need. QMS and the owner decide the review frequency and evidence location; do not invent a schedule.

5. Decisions, errors and stop conditions

- If account identity or requested authority is uncertain, do not provision it.
- Seeing an administrative page is not mutation authorization; every write still requires permission, scope, state and version checks.

6. Records and handoff

- Access request
- Safe user record
- Grant review
- Session revocation and credential audit

Before handoff, reopen the saved record where the application supports it and compare the result with the source. Retain an unresolved outcome as unresolved; do not infer approval from a name, signature image, task completion or test result.

7. Sources and related documents

- Documents/OWNER-DECISION-RBAC-2026-09-23.md
- src/shared/authorization/authorize.ts
- src/modules/identity/application/create-user.ts

Related work instructions: QC-WI-040

Repository sources are bound to HEAD 435f9f704049dee4916223b24b96866d7fa9af2e. Resolve source IDs, file hashes, external editions and form originals in References (source metadata is inside Authoring_Sources.zip).

8. Required decisions before approval

- DEC-016 — Generic signature and document authority
- DEC-024 — Release gates, applicability and human acceptance

Document Control records real reviewer outcomes and actual approval/effectivity only after the controlled process. Completed proposals for these decisions are provided in References/Policy_and_Method_Decision_Book.pdf. Required source evidence and owner adoption remain explicitly recorded there.

9. Current route references

- /
- /login
- /admin
- /admin/users
- /admin/users/new
- /admin/users/[userId]
- /admin/roles
- /admin/roles/[roleId]

- /admin/permissions
- /admin/scopes
- /account

Route placeholders identify existing records. Route coverage is documentation mapping, not proof that every role/state was accepted in a browser. Exact extracted field and permission strings are in [References/route-coverage.pdf](#) and [References/source-contract-register.pdf](#).

10. Detailed operating policy and review checks

These are D0.2 proposed operating controls for adoption. Official company records remain valid physical source records; this revision does not retrospectively change their outcomes. Use the operational record named below to capture execution and exceptions.

DEC-016 — Document, change and signature policy

Bind the decision to document number/revision, file digest, actor, role/scope, decision meaning, timestamp and authentication evidence. Preserve rejection/return reasons. Reopening creates a new review cycle without erasing the signed predecessor. A changed file invalidates the pending approval binding and requires renewed review.

Decision and exception check: Proposed separation: author cannot give their own final approval; reviewers may request corrections but may not replace raw evidence; only an approved release/distribution role may make a revision effective. Maintain current application denial for generic approval while RD-019/PD-32 are unresolved. Adopt this policy through the real owner/QMS process before implementation.

Record: QC-REC-009 review, approval and effectivity record; QC-SOP-001/011/022/023.

DEC-024 — Release and human UAT evidence

Freeze source SHA, dirty fingerprint, build/runtime identity and migration state. Define real UAT roles and scenarios, including receiving, inspection/lab review, denial, stale version, uncertain submission, reports and recovery intent. Participants execute with their own authorized accounts and record observed outcome, evidence and defects. Preserve failed and blocked cases.

Decision and exception check: A verification lead checks candidate binding and unresolved defects; the authorized acceptor signs only real participant evidence. A source test, authored script or planned scenario cannot be substituted for the session. If the candidate changes, assess affected evidence and rebind/rerun as required. Gate PASS does not itself execute release or deployment.

Record: QC-REC-017 release gate and UAT session; QC-SOP-030; route-coverage register.

Revision record

D0.2, 2026-10-04: expanded execution, exception and handoff controls; incorporated owner-confirmed official physical forms and completed technical decision proposals. Previous D0.1 sources are retained in History/D0.1 within `Authoring_Sources.zip`. Review and approval remain unrecorded.